

SWE210 - Software Security- Homework 4

Zehra Kolat 206001007

TASK1

Lab 1 – SQL Injection: Login Bypass

Objective:

In this task, a malicious SQL query such as ' **OR 1=1--** ' is placed in the login form. This query creates a vulnerability in the SQL database that always sets the **WHERE** condition to true. In this way, the system is logged in without valid user authentication. The purpose of this lab is to show that authentication can be bypassed using SQL injection in systems with insufficient login validation. Objective: To achieve a login using the SQL Injection vulnerability without having any valid user account information.

Steps Followed:

1. I entered the address `http://localhost:3000`
2. I went to the "Login" screen by clicking on the account icon in the upper right corner.
3. I wrote the following information in the input fields:
 - **Email:** ' OR 1=1--
 - **Password:** any text (I wrote zehra123)
4. I pressed the "Log in" button.

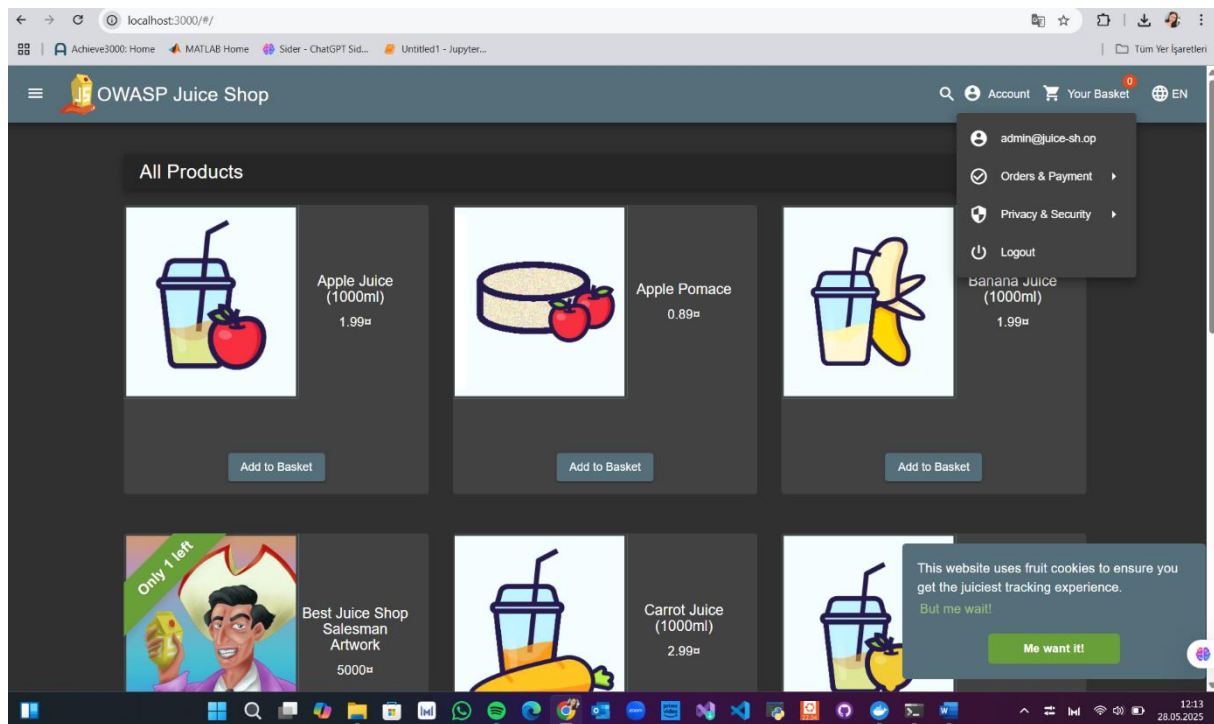
Observations:

- I was able to log into the system with this data, which does not belong to a real user account.
- The application evaluated the logical expression `OR 1=1` as true because it directly executed the SQL command.

Outcome:

This vulnerability demonstrates that the SQL Injection attack was successful and the login control was bypassed. That is, the login was successful.

Screenshot:



Lab 2 – Broken Access Control: Discovering Admin Page

Objective:

This lab aims to test whether it is possible to access pages such as the admin panel without any authorization. Purpose: To test whether it is possible to access the hidden admin page directly from the URL without any admin authorization. This is a panel that normally only admin users can access.

Steps Followed:

1. I typed this into the address bar of my browser:
`http://localhost:3000/#/administration`
2. I tried to Access the page.

Observations:

- I was able to access the admin panel without any user login or admin verification.
- The page was opened directly without authorization check.
- The page opened successfully and I saw a title like "Administration".

 This indicates that the **Access Control** mechanism is not sufficient..

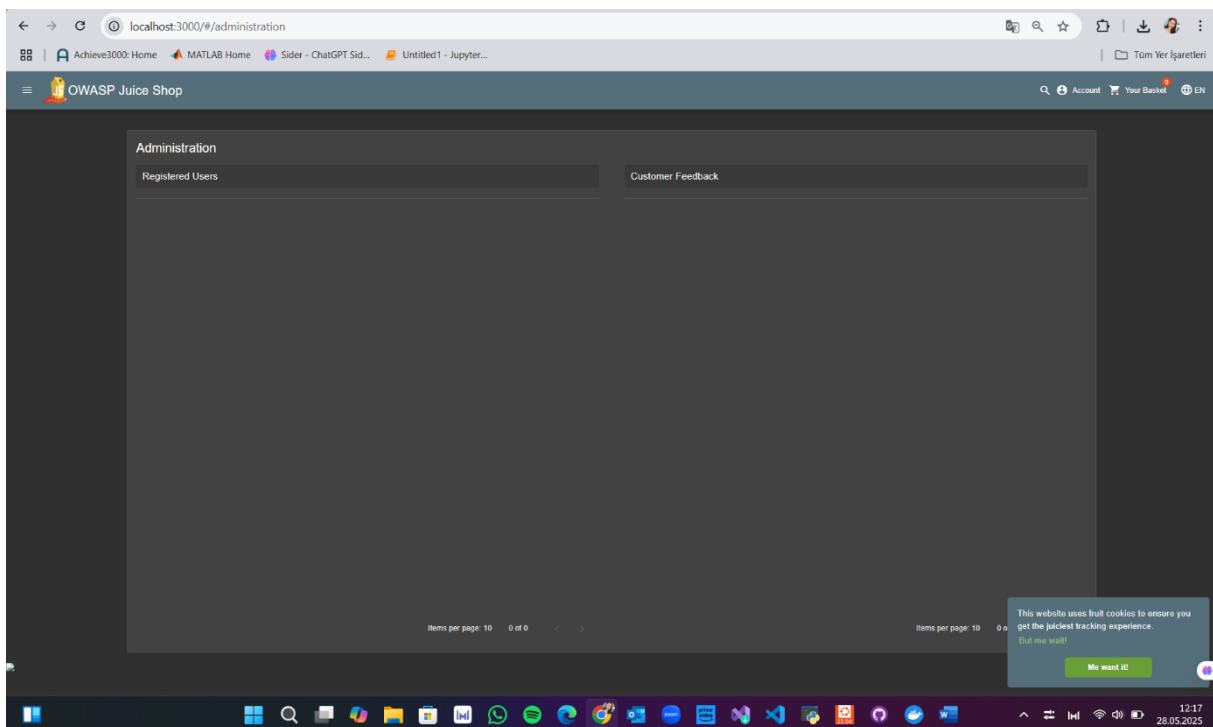
✅ Outcome:

This demonstrates a Broken Access Control vulnerability. Failure to check user permissions could allow malicious actors to access critical admin pages. In this task, accessing the application's admin page directly via a URL without having admin user privileges was tested.

Since the application did not perform the necessary authorization check, the admin panel was accessed from the address **http://localhost:3000/#/administration**

Sonuç: The admin panel was accessed as an unauthorized user.

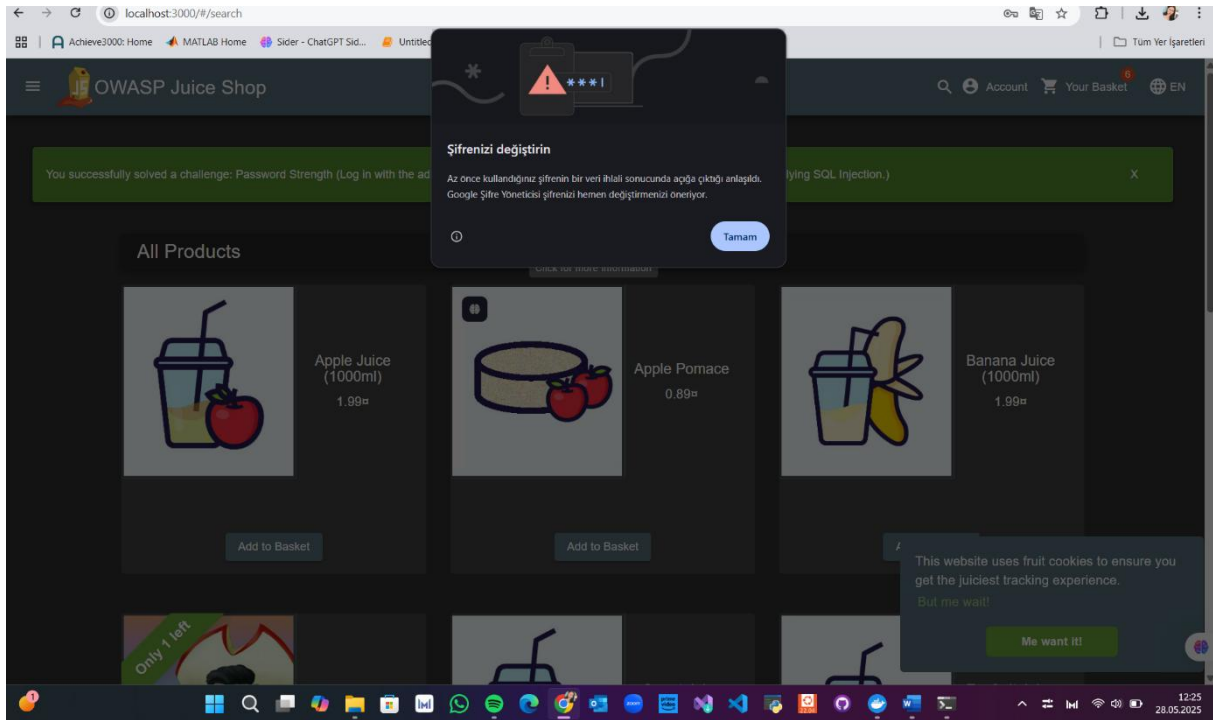
🖼️ Screenshot:



Additionally, Google has issued a data privacy warning:

change your password

it has been discovered that the password you just used was compromised in a data breach. google password manager recommends that you change your password immediately.



Lab 3 – Sensitive Data Exposure in Browser Storage

Objective:

This lab aims to reveal the security risks that may arise from storing sensitive data in the browser without encryption. Namely, Purpose: To detect sensitive data (e.g. tokens, user information) stored unencrypted on the browser (Local Storage and Session Storage).

In this task, the unencrypted sensitive data of the logged-in user in the browser storage (Local Storage and Session Storage) was examined. As a result of the examination, it was determined that the access token and user information were stored in plain text.

This could lead to a malicious user accessing this data and hijacking the session.

Steps Followed:

1. I logged in with any user account..
2. Open developer tools (F12).
3. I moved to the "Application" tab.
4. I selected "Local Storage" → `http://localhost:3000` from the left menu.
5. I looked at the stored data.

Observations:

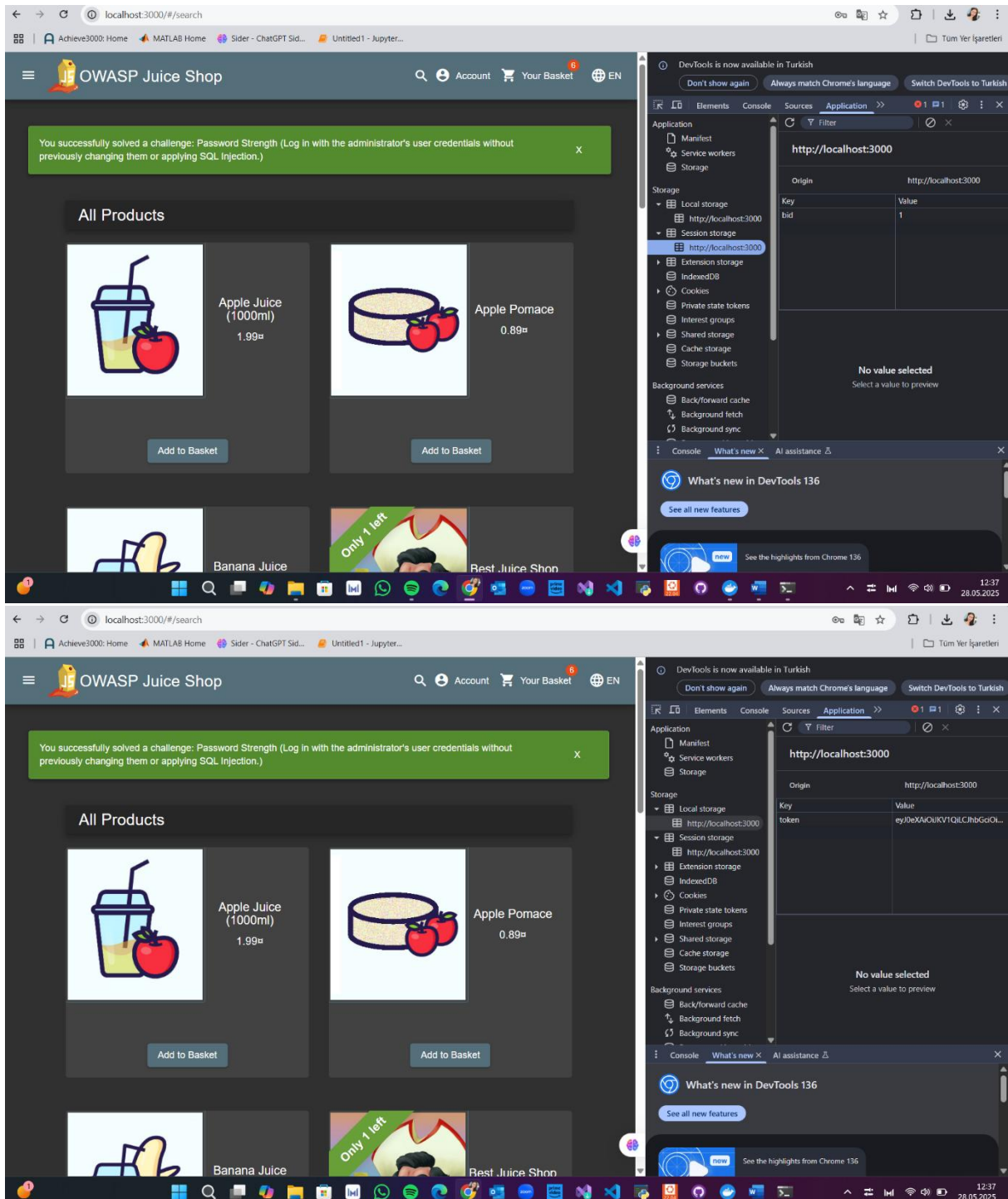
- I observed that session information such as tokens are kept unencrypted in Local Storage.
- It was enough to use only browser developer tools to access this information..

✅ Outcome:

This is a vulnerability classified as **Sensitive Data Exposure**. Sensitive data stored in the browser without being encrypted in the open can be easily intercepted by a malicious individual.

📸 Screenshot:

→



Lab 4 – Session Hijacking via Exposed Token

Objective:

The purpose of this lab is to demonstrate a session hijacking attack, which is performed by malicious actors reusing a session token located in the local storage of a user's browser.

Steps Followed:

1. I logged into the system with a valid user account.
2. I opened the developer tools (F12) and went to the "Application" tab.
3. I found the token key under "Local Storage" → `http://localhost:3000` and copied its value.
4. I logged out of the system (Logout).
6. In the same tab, I pasted the token value back into Local Storage (recreated it if necessary).
1. I refreshed the page (with the F5 key).

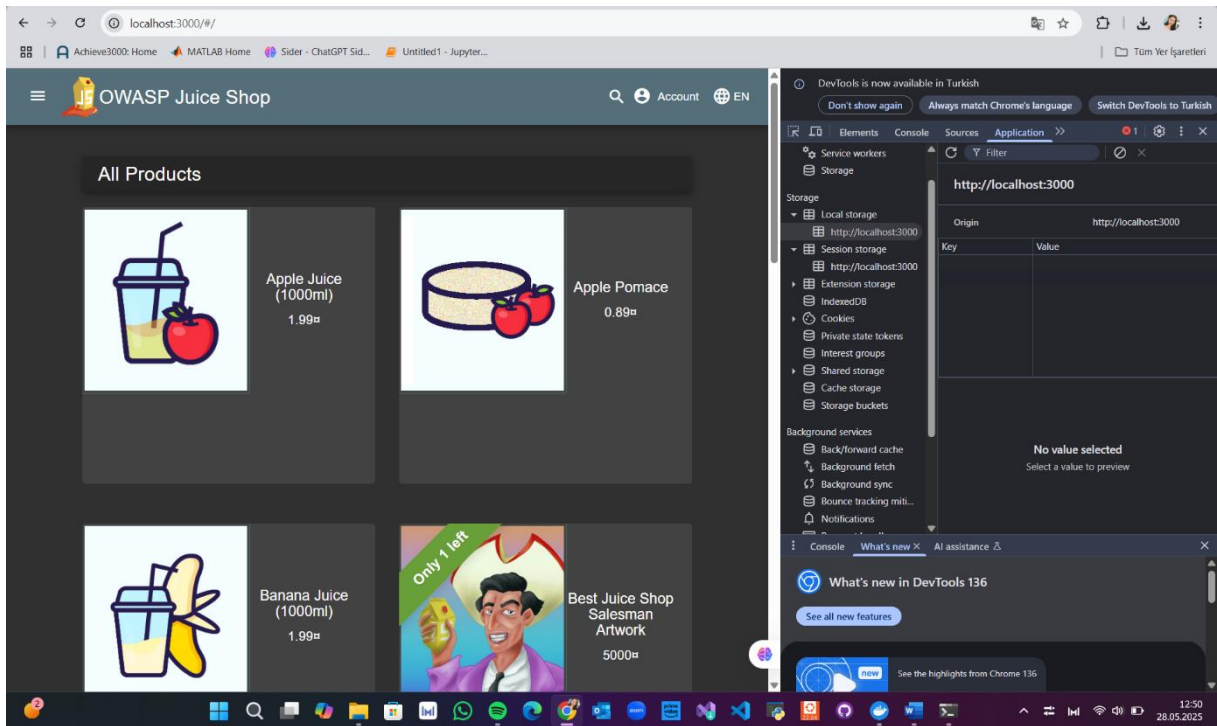
Observations:

- After refreshing the page, the system recognized me as having logged in again as the previous user, even though I had not logged in again.
- This indicated that the token was stored in an unsafe manner and could be misused.

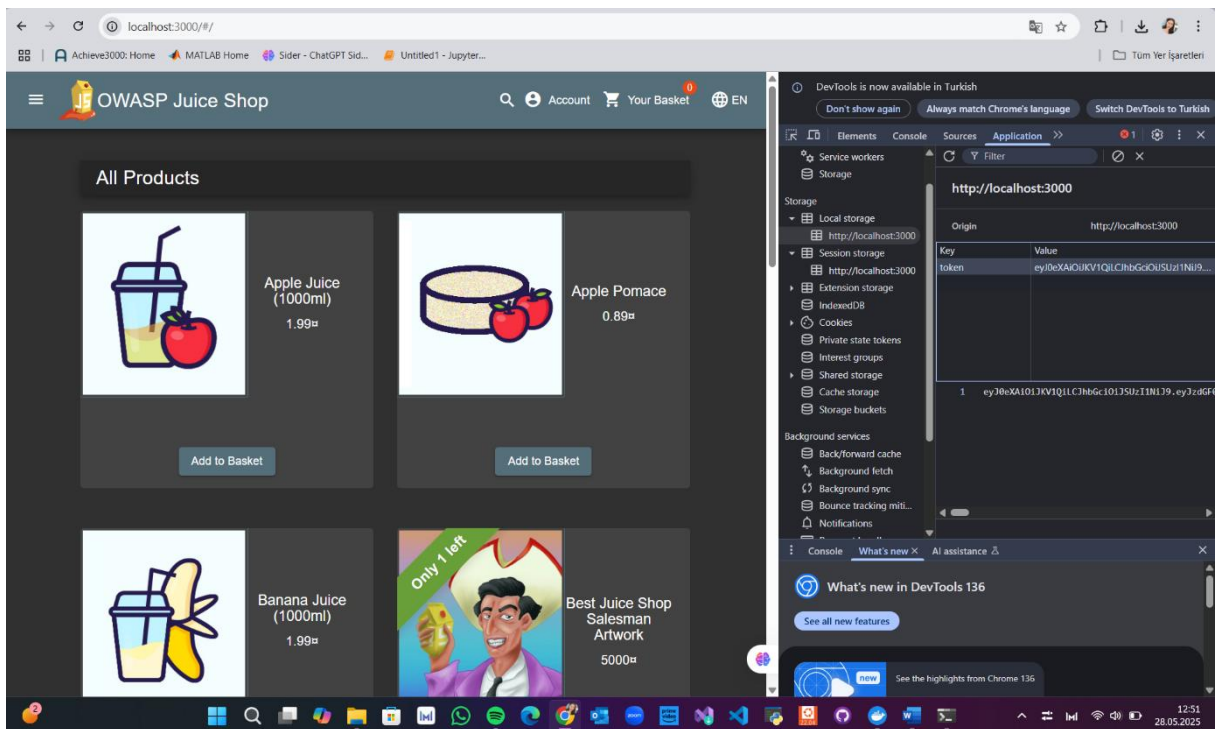
Outcome:

Once the session token is compromised, the attacker can access the user account without needing any password or username. This is a serious security vulnerability.

Screenshot:



Here is the screen where I add the token back to Local Storage after logging out.



Re-login screen after refresh.

TASK 2:

Detecting Zero-Day Web Attacks with an Ensemble of LSTM, GRU, and Stacked Autoencoders

Authors: Vahid Babaey, Hamid Reza Faragardi

Year of Publication: 2025

Research Problem / Objective

a. What issue or challenge is the paper addressing?

This paper focuses on the significant challenges in detecting zero-day web attacks. Traditional signature-based intrusion detection systems are inadequate in detecting previously unseen or unknown types of attacks. Therefore, a new and advanced method is developed to detect unknown attacks early and accurately. The aim of the study is to present a more effective and reliable intrusion detection system in web security.

Methodology / Approach

a. What techniques, models, or experiments were used?

In the research, three different deep learning models, Long Short-Term Memory (LSTM), Gated Recurrent Unit (GRU) and Stacked Autoencoder models, were used. These models were trained separately to analyze sequential time series data and attack behaviors, and then the outputs of these models were combined (ensemble method) to form a single decision mechanism. Thus, the overall detection performance was increased by utilizing the strengths of each model.

Key Findings / Results

a. What were the outcomes or major contributions?

The results show that the proposed ensemble model detects zero-day attacks with high accuracy and has a very low false positive rate. It is also found that the model combination provides more effective and robust performance in attack detection compared to a single deep learning model. This approach offers a promising solution for real-world applications.

Strengths and Limitations

a. What was done well, and what could be improved?

The strength of the paper is that it combines the advantages of different deep learning models to develop a comprehensive detection system. Thanks to the ensemble approach, both accuracy is increased and resistance to different types of attacks is ensured. However, this complex model architecture can lead to high computational costs and thus performance problems in real-time applications. This situation requires improvement for the scalability and practical use of the system.

Reflection

a. How does this article relate to what you've learned in class?

b. Any interesting insight or idea you gained?

This study embodies the theoretical knowledge we learned in our course on the applications of deep learning in the field of web security. In particular, approaches to combining attack detection and machine learning models reinforced the knowledge I gained in the course. The fact that ensemble models can produce more reliable results by combining the strengths of different algorithms provided an important insight. This article was also useful in showing how deep learning can play a critical role in cybersecurity solutions in the future.

Web Attacks Detection Using Stacked Generalization Ensemble for LSTMs and Word Embedding

Authors: Rokia Lamrani Alaoui, El Habib Nfaoui

Year of Publication: 2024

Research Problem / Objective

a. What issue or challenge is the paper addressing?

This article aims to develop a more effective attack detection method by addressing the challenges in detecting text-based web attacks. In particular, advanced techniques are needed to accurately capture complex patterns in sequential and textual data.

Methodology / Approach

a. What techniques, models, or experiments were used?

In the research, the data was first converted to digital form using Word Embedding techniques. Then, LSTM models were trained in different configurations. In the last stage, the outputs of these models were combined with the stacked generalization method to create the final decision mechanism. This approach aims to increase the intrusion detection performance by taking advantage of the strengths of different models. The authors state that the proposed approach provides higher success in attack detection compared to classical methods. It has been concluded that the combined use of LSTM and word embedding provides a great advantage in security detection, especially in systems working with sequential data.

Key Findings / Results

a. What were the outcomes or major contributions?

The proposed method has shown a higher success rate compared to classical signature-based and single deep learning models. It has been shown that attacks in text

data can be identified effectively and accurately. This shows that the method is a powerful and applicable solution for web security.

Strengths and Limitations

- a. What was done well, and what could be improved?

The combination of Word Embedding and LSTM is quite successful in analyzing language-based attacks and can capture patterns in text data well. However, due to the complexity of the model, the training process takes a lot of time and requires large data sets. This may create performance problems when used in real-time systems.

Reflection

- a. How does this article relate to what you've learned in class?
- b. Any interesting insight or idea you gained?

It was very interesting for me to see how effective the LSTM and Word Embedding techniques we learned in our course were in practice. Also, understanding the applications of ensemble methods such as stacking in the security field gave me an important perspective on how machine learning models can be strengthened. This article helped me understand the future potential of deep learning-based methods in the field of web attack detection. The success of LSTM in capturing long-term dependencies, especially in sequential data (time series or text-based data), was emphasized. (From the time series analysis and forecasting course given by Dr. Lecturer Nadi Serhan Aydın last semester). I learned how ensemble techniques like stacking reduce the error rate by combining the strengths of different models. This way, I learned that more robust and fault-tolerant structures can be created in security systems.

Research on Deep Learning and Feature Aggregation Techniques for Web Security

Authors and Year: Jinxin Wang, 2025

Research Problem/Objective

- a. What issue or challenge is the paper addressing?

This study investigates the effect of combining features obtained from different data sources on the detection of web attacks. Since traditional single model approaches are insufficient to detect some types of attacks, it is aimed to develop more accurate and reliable intrusion detection systems by integrating deep learning models with feature engineering techniques. In particular, we focus on the contribution of information integrity between data sources to intrusion detection performance.

Methodology / Approach

- a. What techniques, models, or experiments were used?

Deep learning models such as convolutional neural networks (CNN) and long-short term memory cells (LSTM) were used in the research. They were combined with traditional feature engineering methods to form a hybrid structure. Feature fusion techniques were applied to reveal common and complementary aspects of data from different sources, thus providing rich and multidimensional data representations for attack detection. The models were tested on realistic datasets containing various types of web attacks.

Key Findings / Results

- a. What were the outcomes or major contributions?

The use of feature fusion techniques has significantly increased the attack detection accuracy of the model. Thanks to this method, the distinction between different attack types has been made more clearly and the classification success has been increased. In addition, the capacity of deep learning models to learn complex features from different data sources has strengthened the effectiveness of intrusion detection systems. However, the high computational cost brought by the complex structure and limited performance have still been observed in some attack types.

Strengths and Limitations

- a. What was done well, and what could be improved?

This study makes a significant contribution in terms of successfully demonstrating the hybrid use of deep learning and feature engineering techniques. In particular, its strengths are that it deeply examines the effect of data integration on attack detection and presents a model that can be applied in practice. On the other hand, due to the complexity of the system, high training and processing costs may create difficulties in real-time applications. In addition, additional optimizations are required to improve the performance of the model in some attack types.

Reflection

- a. How does this article relate to what you've learned in class?
- b. Any interesting insight or idea you gained?

This article was very valuable in showing how the feature engineering and deep learning concepts I learned in the course can be effectively combined. It helped me understand how integrating different data sources with a multidisciplinary approach can increase the success of detection systems in the field of web security. In addition, the discussions on model complexity and implementation difficulties increased my awareness of the problems that can be encountered in practice. This study provided an important perspective on how security solutions should be more comprehensive and data-driven in the future.